

WEEK 4 - Advanced Threat Detection & Web Security Enhancements

Prepared By:

Nabira Khan
Cybersecurity Intern
Date: July 23, 2025

1. Objective

The objective of this week's implementation was to strengthen the backend API security posture through intrusion monitoring, brute-force protection, proper request origin control, and implementation of modern HTTP security headers. The focus was on securing user authentication endpoints, applying restrictions to API access, and enforcing safe communication protocols (HTTPS).

2. Tools Used

- **Fail2Ban:** For real-time intrusion detection and IP blocking based on failed SSH login attempts.
- **express-rate-limit:** For brute-force protection by limiting login attempts.
- **cors:** To restrict incoming requests to allowed origins only.
- **helmet:** To set standard HTTP security headers (X-Frame-Options, Content-Security-Policy, etc.).
- **Custom Middleware:** Used to manually set HSTS and advanced headers like Referrer-Policy and Permissions-Policy.

3. Security Enhancements Implemented

Security Area	Implementation
Intrusion Detection	Configured Fail2Ban to monitor and ban IPs with repeated SSH login failures. Provides real-time protection at the OS level.
Rate Limiting	Applied on <code>/login</code> route using <code>express-rate-limit</code> . Limited to 5 requests per 15 minutes per IP to mitigate brute-force attacks.

CORS Policy	Configured using <code>cors</code> middleware to accept requests only from <code>http://localhost:3000</code> . Blocks unauthorized cross-origin access.
Content Security Policy (CSP)	Set strict CSP rules via <code>helmet.contentSecurityPolicy</code> to block inline scripts and control external sources.
HTTPS Enforcement (HSTS)	Used <code>Strict-Transport-Security</code> header to ensure clients use HTTPS connections.
Other Security Headers	Manually added headers for additional protections:

- `X-Frame-Options: DENY` (prevents clickjacking)
- `X-Content-Type-Options: nosniff` (forces MIME-type checking)
- `Referrer-Policy: strict-origin-when-cross-origin`
- `Permissions-Policy: geolocation=(), microphone=()` (limits browser permissions)

4. Justifications for Partial Implementation

Item	Status	Justification
API Key or OAuth Authentication	Not Implemented	For this stage, the app does not include multi-user or third-party API integrations requiring token-based auth. Reserved for later iterations.